

7-Network Discovery - Scan-ta Clause

Introduction



Los preparativos navideños se retrasan: ¡HopSec ha vulnerado nuestro entorno de control de calidad y nos ha bloqueado el acceso! Sin él, los proyectos de TBFC no pueden probarse y todo nuestro flujo de trabajo SOC-mas está congelado. Para empeorar las cosas, el servidor se está transformando lentamente en un nodo EAST-mas retorcido.

¿Podrás descubrir el rastro de HopSec, encontrar la manera de volver a tbfc-devqa01 y restaurar el servidor antes de que el conejo se apodere de todo? Para esta tarea, tendrás que revisar cada escondite y cada puerto abierto que los conejos dejaron desprotegido. ¡Mucha suerte!



Objetivos de aprendizaje

- Aprenda los conceptos básicos del descubrimiento de servicios de red con Nmap.
- Aprenda los protocolos y conceptos básicos de red a lo largo del camino.
- Aplique sus conocimientos para encontrar la manera de volver al servidor.

Discover Network Services

Descubriendo Servicios Expuestos

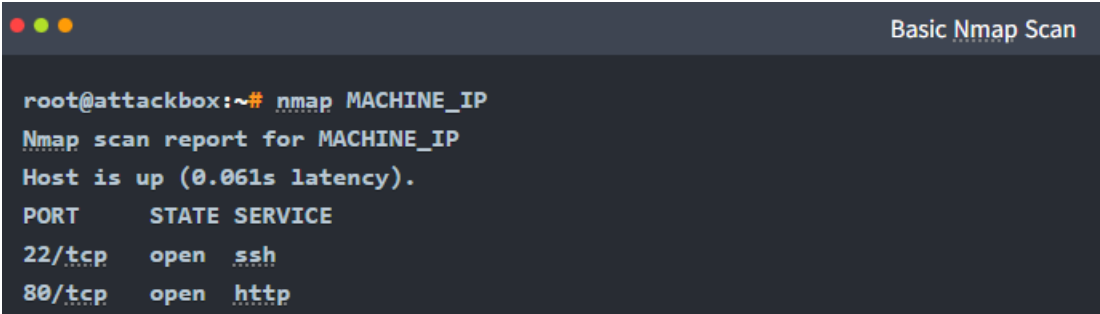
Aunque perdimos el acceso al servidor de control de calidad, al menos sigue activo y conocemos su dirección IP. Buenas noticias, ya que ahora podemos contraatacar y, con suerte, encontrar la manera de recuperarnos. Asegúrate de comprender conceptos básicos de redes, como los puertos de red, ¡y planifiquemos la acción!

1. Conoce tu objetivo. En nuestro caso, es el servidor tbfc-devqa01 con la dirección IP MACHINE_IP.
2. Analiza la IP en busca de puertos abiertos, especialmente los comunes como el 22 para SSH y el 80 para HTTP.
3. Explora qué hay detrás de los puertos abiertos; quizás se trate de un servidor web vulnerable ejecutándose en el puerto 80.
4. Explota el servicio expuesto, encuentra la forma de entrar y expulsa a los usuarios maliciosos del servidor de control de calidad.

Durante la práctica de la tarea de hoy, encontrarás tres claves. Anótalas, ya que las necesitarás más adelante para la aplicación web. El formato será KEYNAME:KEY.

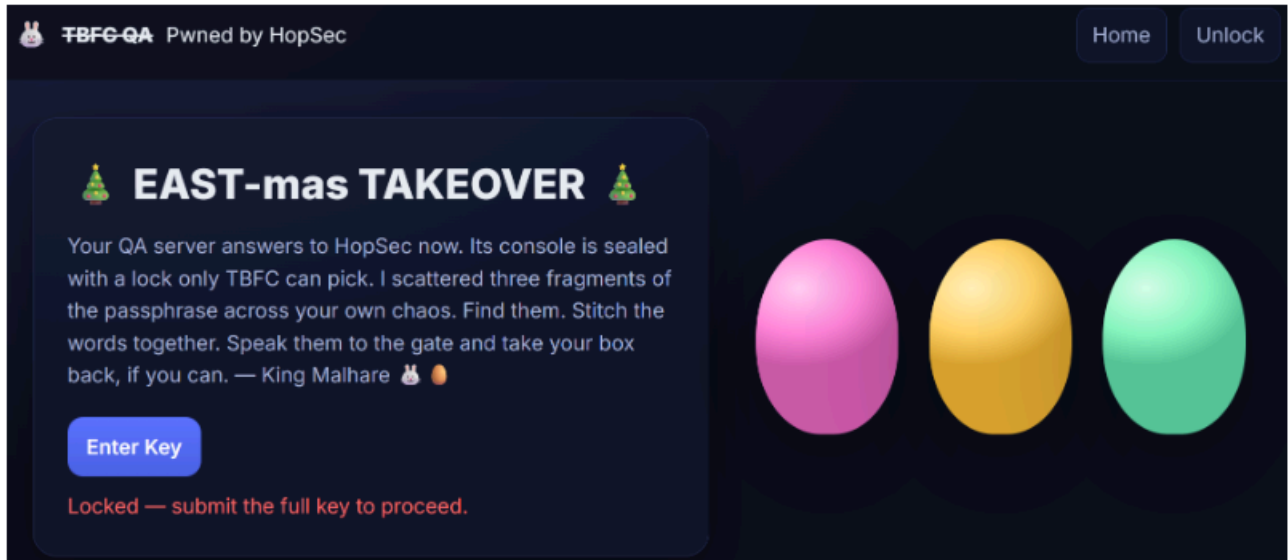
El escaneo de puertos más sencillo

Existen muchas herramientas para escanear puertos abiertos, desde Netcat preinstalado en Linux y PowerShell en Windows, hasta herramientas especializadas y potentes como Nmap y Naabu. Usemos Nmap para esta tarea y realicemos un escaneo básico desde AttackBox o desde su propio equipo atacante conectado a una VPN. Abra una nueva terminal de línea de comandos y ejecute el siguiente comando.



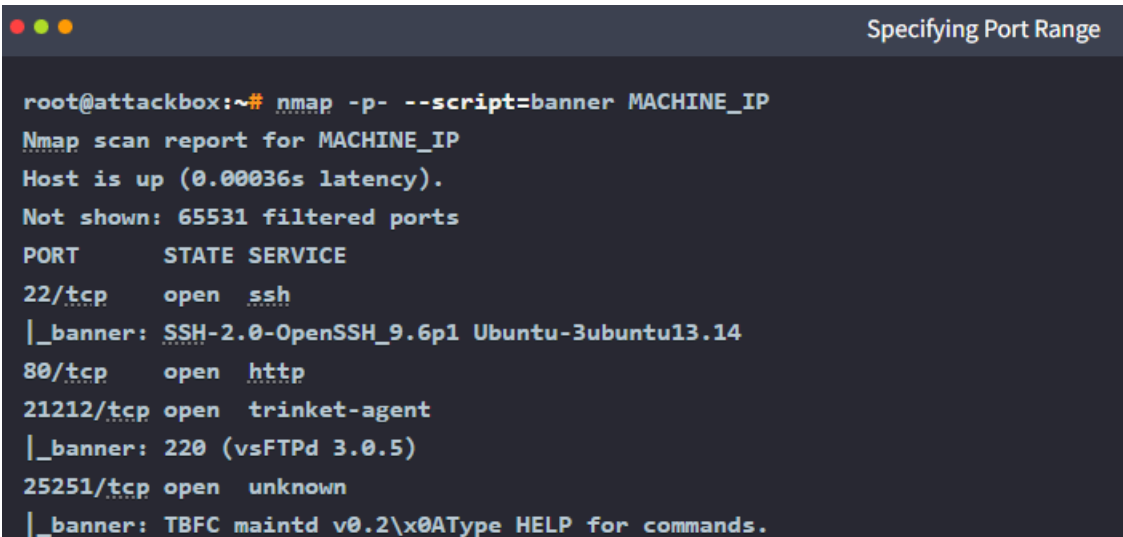
El comando escaneó los 1000 puertos más utilizados e informó si algún servicio se estaba ejecutando allí. Los únicos resultados que obtuvo fueron un puerto SSH abierto para el acceso remoto a la máquina y un puerto HTTP para un sitio web. Esto significa que ahora puede acceder al servidor por SSH (si conoce la

contraseña) o abrir el sitio web visitando http://MACHINE_IP desde AttackBox:

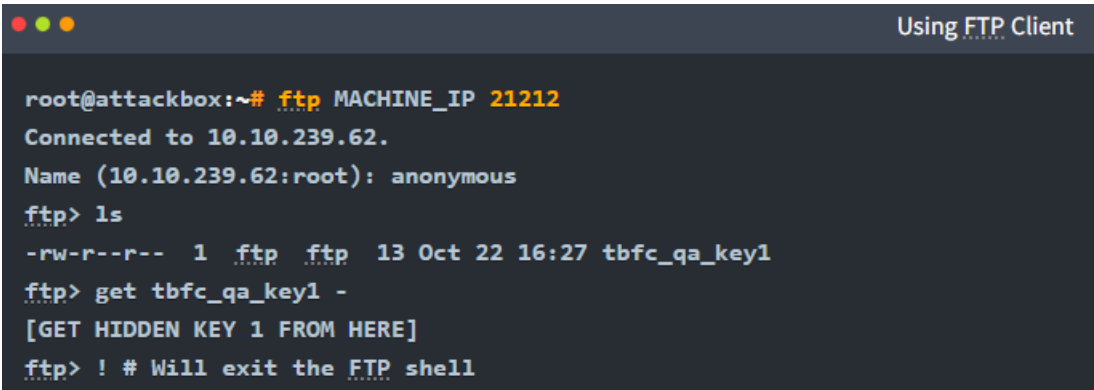


Escaneando todo el rango

Parece que el sitio web está dañado por conejitos malvados, ¡y no sabemos cómo acceder al panel de administración! Pero tranquilos. Solo escaneamos 1000 puertos, ¡pero en realidad hay 65535 puertos donde otros servicios pueden ocultarse! Ahora, agreguemos el argumento `-p-` para escanear todos los puertos y `--script=banner` para ver qué es probable que esté detrás del puerto:

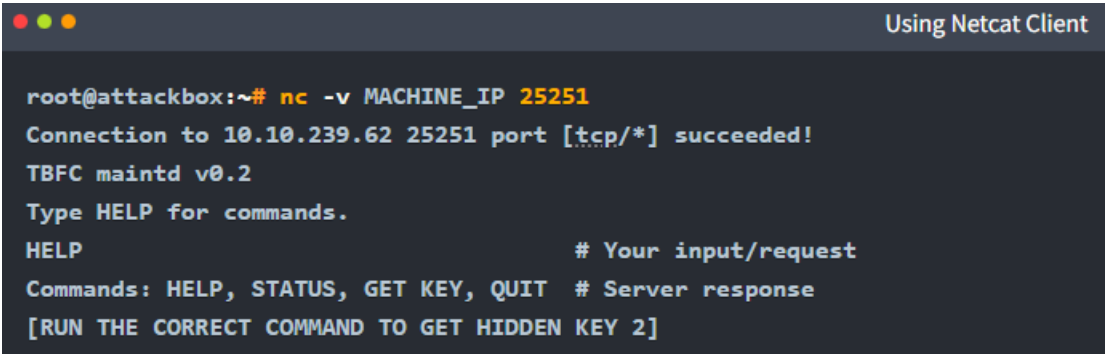


Parece que encontraste un servidor FTP en ejecución y una aplicación TBFC personalizada. Aunque FTP se ejecuta en el puerto 21 por defecto, es posible cambiarlo a cualquier otro, como el 21212. Intentemos acceder al FTP en modo anónimo con el comando `ftp` y veamos si podemos acceder. Puedes seguir los comandos desde la terminal a continuación:



Modos de escaneo de puertos

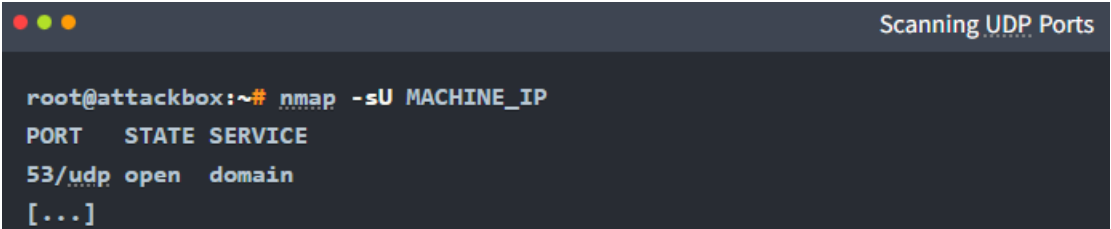
¡Buen trabajo encontrando la primera parte de la bandera! No hay nada más que podamos ver en el servidor FTP, así que pasemos a la aplicación TBFC personalizada en el puerto 25251. Dado que no es un servicio tan conocido como HTTP o FTP, su navegador web o cliente FTP no sabrá cómo acceder a él. Por suerte, siempre puede usar Netcat (`nc`), una herramienta universal para interactuar con servicios de red:



Una vez que reciba la clave, presione CTRL+C para salir del cliente Netcat.

Puertos TCP y UDP

¡Felicitaciones por la segunda bandera! ¿Pero dónde buscar la tercera? Hasta ahora, solo ha escaneado puertos TCP, pero también hay 65535 puertos para UDP, otro protocolo de transporte. ¡Y es posible que también se oculten secretos de HopSec! Puede cambiar al escaneo UDP especificando la bandera `-sU`:



Después de un minuto, debería ver el puerto 53 abierto asociado con DNS, un protocolo que impulsa la web moderna conectando dominios a direcciones IP, ¡y mucho más! El DNS es un tema complejo y pueden esconderse muchos secretos, pero preguntemos al servidor DNS si conoce la clave usando `dig`, un comando para realizar consultas DNS avanzadas.

Querying DNS Server

```
root@attackbox:~# dig @MACHINE_IP TXT key3.tbfc.local +short
[ RUN THE CORRECT COMMAND TO GET HIDDEN KEY 3 ]
```

Descubrimiento de servicios en el host

Ahora que conoces las tres claves del servidor de control de calidad tbfc-devqa01, es hora de llamar a tus compañeros de TBFC y deshacerte de los conejitos malos. Pero primero, inicia sesión en el panel de administración del servidor visitando `http://MACHINE_IP` desde AttackBox y accede a la consola de administración secreta enviando las claves combinadas:



Listado de puertos de escucha

Una vez que tenga acceso a la consola, no es necesario escanear los puertos; simplemente puede solicitar al sistema operativo que enumere sus puertos abiertos, también llamados puertos de escucha. Puede hacerlo ejecutando `ss -tunlp` (o `netstat` en sistemas más antiguos) dentro de la consola de administración secreta de la aplicación web. En la salida, puede ver exactamente los mismos servicios que escaneó antes, escuchando en 0.0.0.0, pero también algunos escuchando en 127.0.0.1 (disponibles solo desde el host):

Listing Listening Ports

```
tbfcapp@tbfc-devqa01:~$ ss -tunlp
```

Netid	State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port	Process
udp	UNCONN	0	0	0.0.0.0:53	0.0.0.0:*	
udp	UNCONN	0	0	10.10.76.132:568	0.0.0.0:*	
tcp	LISTEN	0	50	0.0.0.0:25251	0.0.0.0:*	
tcp	LISTEN	0	32	0.0.0.0:21212	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:22	0.0.0.0:*	
tcp	LISTEN	0	32	0.0.0.0:53	0.0.0.0:*	
tcp	LISTEN	0	511	0.0.0.0:80	0.0.0.0:*	
tcp	LISTEN	0	2048	127.0.0.1:8000	0.0.0.0:*	
tcp	LISTEN	0	151	127.0.0.1:3306	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.1:7681	0.0.0.0:*	
tcp	LISTEN	0	4096	:::22	:::*	

Con permisos de root, también puede ver la columna de proceso. Sin embargo, por ahora, centrémonos en el puerto 3306, que es el puerto predeterminado de la base de datos MySQL. Normalmente, las bases de datos requieren una contraseña para los clientes remotos, pero permiten inicios de sesión no autenticados desde el host local. Dado que ya está dentro del host, veamos el contenido de la base de datos usando el programa MySQL:

Enumerating MySQL Tables

```
tbfcapp@tbfc-devqa01:~$ mysql -D tbfcqa01 -e "show tables;"
+-----+
| Tables_in_tbfcqa01 |
+-----+
| flags               |
+-----+

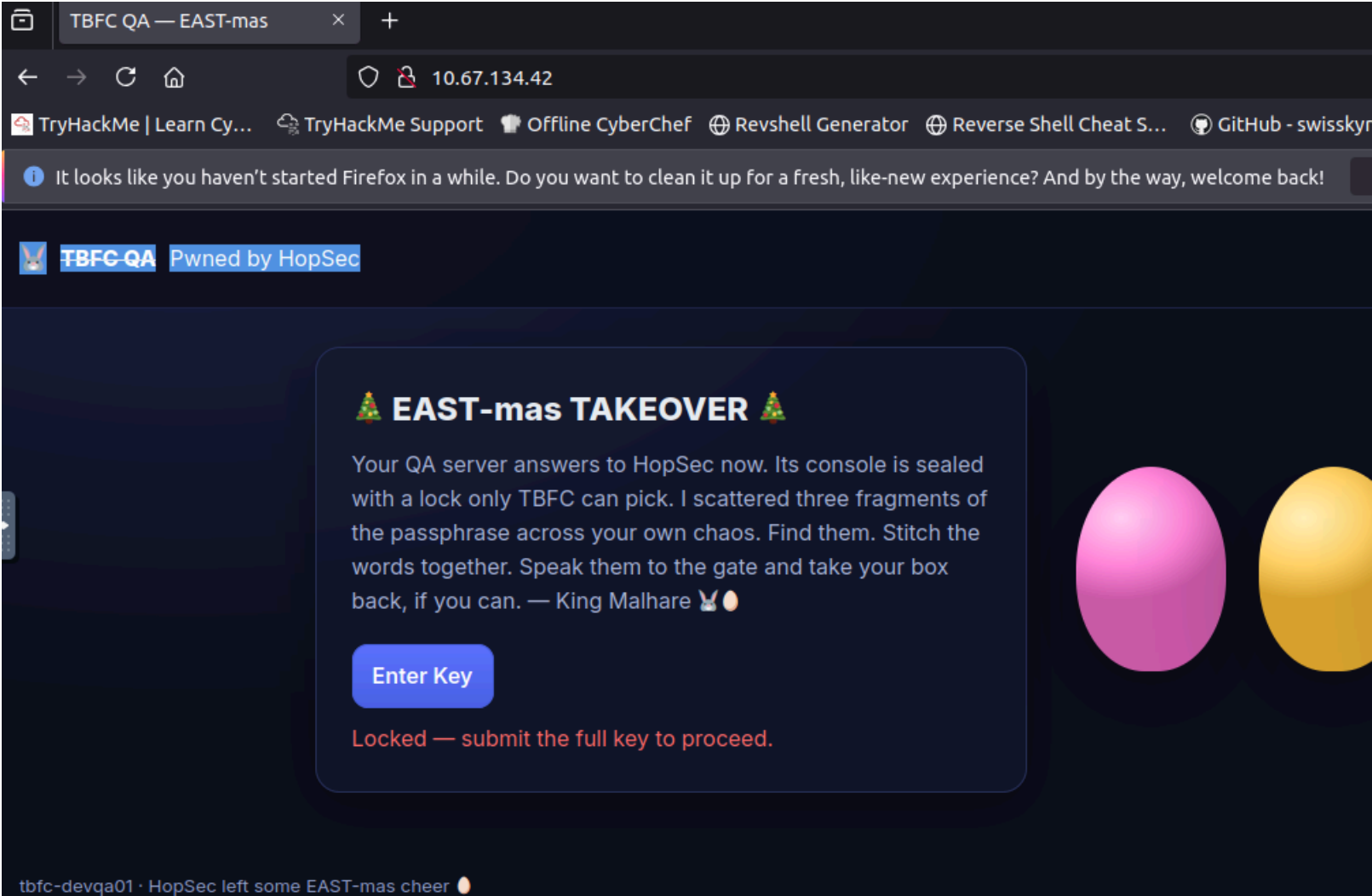
tbfcapp@tbfc-devqa01:~$ mysql -D tbfcqa01 -e "select * from flags;"
[ GET YOUR FLAG HERE ]
```

¡Buen trabajo encontrando la bandera! Has revelado los secretos de todos los conejos y has recuperado el acceso completo al servidor de control de calidad. Ahora es momento de asegurar todos los puertos y restaurar el flujo de trabajo de preparación de SOC-mas. Pero por ahora, ¡responde las preguntas a continuación y completa la tarea!

Answer the questions below

What evil message do you see on top of the website?

Respuesta: Pwned by HopSec



What is the first key part found on the FTP server?

Respuesta: 3aster_

```
root@ip-10-67-73-10:~# ftp 10.67.134.42 21212
Connected to 10.67.134.42.
220 (vsFTPD 3.0.5)
Name (10.67.134.42:root): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-r--r--    1 ftp      ftp           13 Oct 22 16:27 tbfc_qa_key1
226 Directory send OK.
ftp> get tbfc_qa_key1
local: tbfc_qa_key1 remote: tbfc_qa_key1
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for tbfc_qa_key1 (13 bytes).
226 Transfer complete.
13 bytes received in 0.00 secs (24.7955 kB/s)

root@ip-10-67-73-10:~# cat tbfc_qa_key1
KEY1:3aster_
```

What is the second key part found in the TBFC app?

Respuesta: 15th3

```
root@ip-10-67-73-10:~# nc -v 10.67.134.42 25251
Connection to 10.67.134.42 25251 port [tcp/*] succeeded!
TBFC maintd v0.2
Type HELP for commands.
HELP
Commands: HELP, STATUS, GET KEY, QUIT
GET KEY
KEY2:15_th3_
```

What is the third key part found in the DNS records?

Respuesta: n3w_xm45

```
root@ip-10-67-73-10:~# dig @10.67.134.42 TXT key3.tbfc.local +short
"KEY3:n3w_xm45"
```

Which port was the MySQL database running on?

Respuesta: 3306

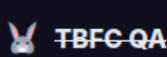
Finally, what's the flag you found in the database?

```
Respuesta: THM{4Il_s3rvic35_d1sc0vered}
tbfcapp@tbfc-devqa01:~$ mysql -D tbfcqa01 -e "show tables;"
+-----+
| Tables_in_tbfcqa01 |
+-----+
| flags              |
+-----+
tbfcapp@tbfc-devqa01:~$ █
```

```
tbfcapp@tbfc-devqa01:~$ mysql -D tbfcqa01 -e "select * from flags;"
+-----+
| id | flag                                     |
+-----+
| 1  | THM{4ll_s3rvice5_d1sc0vered} |
+-----+
tbfcapp@tbfc-devqa01:~$
```

If you enjoyed today's room, feel free to check out the [Nmap: The Basics](#) room.

No Needed answerd

 **TBFC QA** Pwned by HopSec

Home

Unlock

Unlock

Combine the three parts into: <Key1>_<Key2>_<Key3>

3aster_15_th3_n3w_xm45

Unlock

Unlock

Combine the three parts into: <Key1>_<Key2>_<Key3>

XXXX_XXXX_XXXX

Unlock

Correct key. Terminal is now available.

Go to Terminal

Secret Admin Console

```
tbfcapp@tbfc-devqa01:~$
```